



Prinsip Risiko, Internal Control, dan Application Control

Audit Sistem Informasi

Program Studi Sistem Informasi

Universitas Jenderal Achmad Yani

Irma Santikarama

Daftar Isi



01

Capaian Pembelajaran

Learning outcomes dan kompetensi yang diharapkan

02

Permasalahan dalam Perusahaan

Kesalahan umum yang terjadi dalam organisasi

03

Konsep dan Jenis Risiko

Pengertian risiko dan klasifikasinya

04

Pengelompokan Risiko

Kategori risiko menurut berbagai perspektif

05

Pengendalian Internal

Prinsip, tujuan, dan kriteria informasi

06

IT Governance

Konsep dan sumber daya teknologi

07

Application Control Framework

Jenis-jenis pengendalian aplikasi

08

Studi Kasus

Analisis kasus sistem pembayaran online

09

Referensi

Daftar pustaka dan sumber referensi

Learning Outcomes



Memahami Konsep Risiko

Mahasiswa mampu menjelaskan konsep risiko secara komprehensif, memahami jenis-jenis risiko dalam konteks audit sistem informasi, serta mengidentifikasi faktor-faktor yang mempengaruhi tingkat risiko dalam organisasi.



Internal Control

Mahasiswa memahami prinsip-prinsip dasar pengendalian internal, tujuan pengendalian, serta kriteria informasi yang baik sesuai dengan framework yang berlaku.



Application Control

Mahasiswa mampu menjelaskan framework application control, memahami berbagai jenis pengendalian aplikasi, dan mengaplikasikannya dalam konteks sistem informasi.



Analisis dan Identifikasi

Mahasiswa mampu mengidentifikasi risiko dan kontrol yang diperlukan dalam sistem informasi, serta menganalisis studi kasus audit sistem informasi secara sistematis.

Permasalahan Umum dalam Perusahaan



Kesalahan Pencatatan

Kesalahan pencatatan laporan keuangan akibat sistem akuntansi yang tidak memadai, menyebabkan informasi keuangan tidak akurat.



Biaya Tidak Efisien

Biaya operasional tidak efisien, misalnya pembelian bahan baku terlalu mahal karena kurangnya pengendalian pengadaan.



Pendapatan Kurang Optimal

Pendapatan usaha yang kurang maksimal, dapat terjadi karena banyaknya piutang yang tidak tertagih atau sistem penjualan yang lemah.



Kecurangan & Pencurian

Terjadi kecurangan atau pencurian aset oleh pihak internal maupun eksternal karena sistem pengamanan yang lemah.



Kurangnya Disiplin

Kurang disiplinnya pegawai dalam menjalankan prosedur dan kebijakan yang telah ditetapkan oleh organisasi.



Penyelewengan Kewenangan

Penyelewengan kewenangan oleh pihak manajemen serta kondisi persaingan yang tidak menguntungkan.



Mengapa Ini Terjadi?

Permasalahan-permasalahan ini seringkali disebabkan oleh lemahnya sistem pengendalian internal dan kurangnya pemahaman tentang manajemen risiko dalam organisasi.

"Sistem pengendalian yang efektif dapat mencegah atau mendeteksi kesalahan dan kecurangan sejak dini."

Pengertian dan Jenis-Jenis Risiko

Definisi Risiko

Risiko adalah kemungkinan terjadinya peristiwa yang dapat menghambat pencapaian tujuan organisasi.

"Risiko bukan sesuatu yang harus dihindari, tetapi harus dikelola dengan baik."

Karakteristik Risiko

- ✓ Selalu ada dalam setiap aktivitas bisnis
- ✓ Dapat diidentifikasi dan dianalisis
- ✓ Dapat dikelola dan dikendalikan

Jenis-Jenis Risiko dalam Audit



Business Risk

Risiko akibat faktor internal atau eksternal yang mempengaruhi pencapaian tujuan bisnis organisasi.



Inherent Risk

Risiko bawaan yang melekat pada suatu aktivitas atau proses bisnis sebelum adanya pengendalian.



Control Risk

Risiko bahwa sistem pengendalian internal tidak mampu mencegah atau mendeteksi kesalahan material.



Detection Risk

Risiko bahwa auditor tidak berhasil menemukan kesalahan material yang terjadi dalam laporan keuangan.



Audit Risk

Kombinasi dari Inherent Risk, Control Risk, dan Detection Risk yang merupakan risiko keseluruhan dalam proses audit.

Formula Audit Risk

$$\text{Audit Risk} = \text{IR} \times \text{CR} \times \text{DR}$$

IR

Inherent Risk

CR

Control Risk

DR

Detection Risk

Implikasi dalam Perencanaan Audit

- 1 Jika Inherent Risk tinggi, auditor perlu mengurangi Detection Risk dengan melakukan pengujian lebih ekstensif.
- 2 Jika Control Risk rendah (pengendalian efektif), auditor dapat mengandalkan pengendalian internal dan mengurangi pengujian substantif.
- 3 Auditor harus menetapkan tingkat Audit Risk yang dapat diterima (misalnya 5%) dan merencanakan prosedur audit sesuai.



Inherent Risk (IR)

Risiko bawaan sebelum adanya pengendalian internal. Semakin kompleks transaksi, semakin tinggi IR.

Contoh: Transaksi estimasi akuntansi memiliki IR lebih tinggi daripada transaksi kas.



Control Risk (CR)

Risiko pengendalian tidak efektif mencegah atau mendeteksi kesalahan material.

Contoh: Jika tidak ada pemisahan tugas, CR akan tinggi.



Detection Risk (DR)

Risiko auditor tidak mendeteksi kesalahan material. DR ditentukan oleh auditor.

Contoh: Semakin banyak sampel yang diuji, semakin rendah DR.

Pengelompokan Risiko

Jones & Rama (2003)



Execution Risk

Risiko Eksekusi

Risiko yang terjadi karena tidak berhasil mencapai tujuan yang telah ditetapkan oleh organisasi.

Contoh: Proyek IT tidak selesai tepat waktu, anggaran membengkak, atau tidak mencapai target kinerja yang diharapkan.



Information Risk

Risiko Informasi

Risiko yang berkaitan dengan penyalahgunaan data atau informasi dalam sistem organisasi.

Contoh: Data pelanggan bocor, informasi keuangan tidak akurat, atau laporan yang menyesatkan.



Asset Protection Risk

Risiko Perlindungan Aset

Risiko terhadap kehilangan atau kerusakan aset fisik maupun non-fisik milik organisasi.

Contoh: Pencurian peralatan, kerusakan fasilitas, atau kehilangan data penting.



Performance Risk

Risiko Kinerja

Risiko yang berkaitan dengan kinerja pegawai dan kemampuan mereka dalam menjalankan tugas.

Contoh: Ketidakmampuan staf IT, kurangnya pelatihan, atau turnover karyawan yang tinggi.

Pengelompokan Risiko

Hunton, Bryan, Barganof (2004)



IT Security Risk

Risiko Keamanan TI

Risiko yang timbul akibat permasalahan keamanan teknologi informasi dalam organisasi.

Contoh Permasalahan:

- > Serangan malware dan virus
- > Akses tidak sah ke sistem
- > Kebocoran data sensitif
- > Kelemahan dalam enkripsi

Dampak: Kerugian finansial, reputasi rusak, pelanggaran regulasi.



Continuity Risk

Risiko Kelangsungan

Risiko yang terjadi berkaitan dengan ketersediaan data/informasi dan stabilitas sistem (backup dan recovery).

Contoh Permasalahan:

- > Kehilangan data tanpa backup
- > Gangguan sistem yang lama
- > Tidak ada disaster recovery plan
- > Server down tanpa redundansi

Dampak: Operasional terhenti, kehilangan transaksi, ketidakpuasan pelanggan.

Pengendalian Internal

Pengertian dan Pengelompokan

Definisi

Pengendalian Internal adalah sistem kebijakan dan prosedur yang dirancang untuk melindungi aset organisasi dan memastikan keandalan informasi.

"Pengendalian internal bukan hanya tugas auditor, tetapi tanggung jawab seluruh manajemen."

Tanggung Jawab

-  **Manajemen**
Bertanggung jawab utama atas implementasi
-  **Tim Ahli**
Dipilih untuk melaksanakan pengendalian
-  **Seluruh Karyawan**
Ikut serta dalam menjalankan prosedur

Pengelompokan (Chusing, 1983)



Pengendalian Administrative

Meliputi struktur organisasi dan prosedur-prosedur, serta catatan-catatan yang berkaitan dengan proses pengendalian keputusan dengan pengesahan transaksi-transaksi oleh manajemen.

Contoh: Struktur hierarki organisasi, prosedur pengambilan keputusan, sistem pengesahan transaksi.



Pengendalian Akuntansi

Meliputi transaksi serta catatan keuangan perusahaan dan konsekuensinya terhadap kemajuan perusahaan.

Contoh: Sistem pencatatan transaksi, rekonsiliasi bank, pengendalian dokumen sumber.

Prinsip Dasar Pengendalian Internal



01 Manajemen Responsibility

Pengendalian internal merupakan tanggung jawab manajemen, bukan hanya auditor.

02 Tim Ahli

Top manajemen memilih tim ahli untuk melaksanakan pengendalian internal secara efektif.

03 Generic & Universal

Sistem bersifat generic, mendasar, dan bisa diterapkan di semua jenis perusahaan.

04 Reasonable Assurance

Sistem pengendalian internal harus memberikan jaminan yang wajar, tidak mutlak.

05 Memiliki Batasan

Sistem pengendalian internal memiliki batasan-batasan dan tidak sempurna.

06 Evaluasi Berkelanjutan

Sistem harus selalu dievaluasi dan disesuaikan dengan perubahan kondisi.



Poin Kunci

Pengendalian internal yang efektif memerlukan komitmen dari seluruh level organisasi dan evaluasi berkelanjutan untuk memastikan keefektifannya.

Tujuan Pengendalian Internal



Menjaga Keandalan Data



Completeness

Kelengkapan data di input, proses, dan output



Accuracy

Keakuratan data di semua tahapan



Uniqueness

Data unik, tidak ada duplikasi



Reasonableness

Data masuk akal dan logis



Error Detection

Kesalahan dapat terdeteksi



Mendorong Kepatuhan



Timeliness

Data dicatat, dimasukkan, dan diproses tepat waktu



Valuation

Penilaian, perhitungan, dan ringkasan yang benar



Classification

Klasifikasi transaksi sesuai kebijakan



Menjaga Aset



Transaction Authorized

Transaksi telah diotorisasi dengan benar



Security of Data

Keamanan catatan data dan dokumen penting

Kriteria Informasi yang Baik



Effectiveness

Apakah informasi yang diharapkan benar-benar bisa diciptakan sesuai kebutuhan pengguna.



Efficiency

Informasi yang diciptakan harus menggunakan sumber daya dengan efisien dan optimal.



Confidentiality

Informasi hanya boleh diakses oleh orang-orang yang berhak untuk mengaksesnya.



Integrity

Keutuhan informasi, informasi yang tidak valid tidak berguna atau cenderung menyesatkan.



Availability

Informasi tersebut tersedia tepat pada waktunya atau ada saat dibutuhkan.



Reliability

Informasi yang dihasilkan harus benar-benar dapat dipercaya dan akurat.



Compliance

Informasi yang dibuat dan disajikan harus sesuai dengan aturan-aturan dan standar internal atau eksternal yang berlaku.



Catatan: Ketujuh kriteria ini saling terkait dan harus dipenuhi secara bersamaan untuk menghasilkan informasi berkualitas yang dapat mendukung pengambilan keputusan.

Definisi IT Governance

IT Governance adalah hubungan antara kebutuhan informasi (**demand**) dan teknologi informasi yang tersedia (**supply**).

Perusahaan membutuhkan informasi, dan tersedia teknologi informasi untuk mendukung ketersediaan informasi yang dibutuhkan tersebut.

Pertanyaan Kunci

Apakah demand (kebutuhan organisasi) dapat langsung bertemu dengan supply (teknologi)?

TIDAK

Hubungan Demand-Supply



Demand

Kebutuhan Informasi



Supply

Teknologi Informasi

Proses yang Diperlukan:

- 1 Pemodelan Bisnis dan Teknologi Informasi
- 2 Perancangan Strategis Teknologi Informasi



Software

Aplikasi dan program yang digunakan untuk mengolah data dan menghasilkan informasi.

Contoh: Sistem ERP, aplikasi akuntansi, database management system.



Hardware

Infrastruktur teknologi fisik yang mendukung operasional sistem informasi.

Contoh: Server, komputer, jaringan, perangkat penyimpanan.



Infoware

Penyedia informasi dan data yang menjadi input dan output sistem.

Contoh: Data pelanggan, data transaksi, data master.



Brainware

Orang atau pengguna teknologi yang mengoperasikan dan mengelola sistem.

Contoh: Staff IT, user, manajer, auditor.



Integrasi Sumber Daya

Keempat sumber daya ini harus terintegrasi dengan baik untuk menghasilkan sistem informasi yang efektif dan efisien.

"Teknologi hanya akan efektif jika didukung oleh sumber daya manusia yang kompeten dan data yang berkualitas."



General Control

Pengendalian Umum

Definisi

Pengendalian yang bersifat umum untuk semua pihak yang terkait dengan komputer dan sistem informasi.

Contoh Penerapan:

- ✓ CCTV di area ATM
- ✓ Larangan menggunakan helm di ATM
- ✓ Keamanan fisik ruang server
- ✓ Kebijakan password untuk semua user

Karakteristik: Berlaku untuk semua aplikasi dan sistem, tidak spesifik pada satu fungsi tertentu.



Application Control

Pengendalian Khusus

Definisi

Pengendalian yang terbatas pada satu aplikasi saja, disebut juga pengendalian aplikasi atau pengendalian khusus.

Contoh Penerapan:

- ✓ Kartu ATM dan PIN untuk transaksi
- ✓ Melihat saldo rekening
- ✓ Penarikan uang tunai
- ✓ Validasi transaksi per aplikasi

Karakteristik: Spesifik untuk aplikasi tertentu, mengontrol proses bisnis spesifik.

Application Control Framework

Overview



Boundary Control

Otoritas dan otentikasi pengguna sistem.

Username, password, hak akses



Input Control

Masukan sistem dan penanganan kesalahan.

Validasi, format, mandatory field



Process Control

Pemeliharaan ketetapan data dalam proses.

Balancing, overflow, matching check



Output Control

Hasil pengolahan sistem dan laporan.

Rekonsiliasi, validasi, distribusi



Database Control

Akses dan integritas data dalam database.

Access control, encryption, backup



Communication Control

Pengendalian gangguan komunikasi.

Transmission, hardware, cyber attack



Framework Lengkap

Enam komponen ini membentuk framework pengendalian aplikasi yang komprehensif untuk memastikan keamanan dan keandalan sistem informasi.

"Setiap komponen saling terkait dan mendukung untuk menciptakan sistem pengendalian yang efektif."

Boundary Control

Pengendalian Batasan Sistem

Definisi

Boundary Control adalah pengendalian yang menjelaskan ruang lingkup sistem dan sub-sistemnya, serta mengatur otentikasi pengguna.

Contoh: Menyalakan mesin ATM dari kondisi mati sampai hidup oleh petugas dengan username dan password.

Tujuan Boundary Control

-  **Otentikasi Pengguna**
Mengetahui siapa yang berhak menggunakan sistem
-  **Perlindungan Sistem**
Menjaga agar sistem tidak disalahgunakan
-  **Definisi Ruang Lingkup**
Menjelaskan batasan sistem dan sub-sistem

Mekanisme Boundary Control



Username

Identifikasi unik untuk setiap pengguna yang akan mengakses sistem.



Password

Kata sandi untuk memverifikasi identitas pengguna yang telah terdaftar.



Pengaturan Hak Akses

Menentukan level akses yang diizinkan untuk setiap pengguna berdasarkan perannya.

Input Control

Pengendalian Masukan



Definisi & Tujuan

Input Control bertujuan untuk meyakinkan bahwa apapun input ke dalam sistem (dapat berupa transaksi, data, dll) adalah **valid** dan **akurat**.

Fungsi Utama:

- ✓ Memastikan data yang masuk valid
- ✓ Mencegah kesalahan entry data
- ✓ Menangani error dengan tepat



Batch System

Karakteristik:

Input diolah atau dikumpulkan terlebih dahulu, baru masuk ke dalam sistem.

Contoh:

- Input transaksi per bulan
- Input form dalam batch
- Pengendalian error entry

Pelaksana: Biasanya dilakukan oleh petugas data entry



On-line Real-time

Karakteristik:

Input langsung masuk ke dalam komputer secara real-time.

Contoh:

- Pencatatan sensus dan pemilu
- Transaksi perbankan online
- Update data real-time

Pelaksana: Entry data langsung oleh pengguna

Definisi

Process Control menjaga agar data tidak error saat terjadinya proses pada sistem dan menjaga agar tidak terjadi kesalahan-kesalahan dalam mengelola data.

"Proses pengolahan data harus terkontrol untuk memastikan integritas dan akurasi hasil."

Pentingnya Process Control (IAI)

- 1 Transaksi yang diolah menggunakan komputer harus terkontrol
- 2 Agar transaksi tidak hilang, dikurangi, atau ditambah tidak semestinya
- 3 Agar kekeliruan pengolahan data dapat diidentifikasi dan dikoreksi tepat waktu

Cara Process Control



Zero Balancing Test

Pengujian keseimbangan nol untuk memastikan total debit sama dengan total kredit.



Overflow Check

Pemeriksaan overflow untuk mendeteksi jika nilai melebihi kapasitas field.



Matching Check

Pemeriksaan kecocokan data antara sumber berbeda untuk memastikan konsistensi.

Definisi & Tujuan

Output Control digunakan untuk menjaga hasil keluaran sistem agar **akurat, lengkap**, dan dapat digunakan **sebagaimana mestinya**.

Output control menghasilkan report atau laporan yang menjadi dasar pengambilan keputusan.

Pentingnya Output Control

- ✓ Memastikan laporan sesuai dengan kebutuhan pengguna
- ✓ Mencegah distribusi laporan ke pihak yang tidak berwenang
- ✓ Menjamin kelengkapan dan keakuratan informasi

Komponen Output Control



Rekonsiliasi Output

Rekonsiliasi output dengan input dan proses untuk memastikan konsistensi data.



Penelaahan & Pengujian

Penelaahan dan pengujian hasil-hasil pengolahan untuk memastikan akurasi.



Pendistribusian Keluaran

Pengendalian distribusi laporan ke pihak-pihak yang berhak menerima.



Database Access

Pengendalian akses ke database untuk memastikan hanya pengguna berwenang yang dapat mengakses data.

User authentication, role-based access



Concurrency Control

Pengendalian sharing resource untuk mencegah konflik saat banyak user mengakses data secara bersamaan.

Locking mechanism, transaction management



Integrity Control

Pengendalian keutuhan data untuk memastikan data tetap konsisten dan akurat.

Referential integrity, constraint validation



File Handling

Pengendalian penanganan file untuk memastikan file diakses dan dimodifikasi dengan benar.

File permission, audit trail



Existence Control

Kemampuan database me-restore data bila terjadi error atau kegagalan sistem.

Backup, recovery, rollback



Data Encryption

Enkripsi data untuk keamanan, terutama data sensitif yang disimpan dalam database.

AES, RSA, hashing



Database Control sangat penting karena database menyimpan aset informasi yang paling berharga bagi organisasi. Kehilangan atau kerusakan data dapat berdampak fatal.



Definisi

Communication Control adalah pengendalian untuk mengatasi gangguan komunikasi dalam transmisi data dan komunikasi antar sistem.

Pengendalian ini penting untuk menjaga integritas dan keamanan data saat ditransmisikan melalui jaringan.

⚠ Mengapa Penting?

- ✓ Data dapat rusak saat transmisi
- ✓ Risiko intersepsi oleh pihak tidak berwenang
- ✓ Gangguan dapat menghentikan operasional

! Jenis Ancaman Komunikasi



Transmission Impairments

Kemungkinan terjadinya kegagalan transmisi data karena noise atau penipisan gelombang.

Solusi: Error detection, retransmission protocol



Component Failure

Kegagalan sistem yang terjadi oleh hardware atau serangan virus.

Solusi: Redundancy, antivirus, monitoring



Subversive Threats

Serangan hacker atau pihak tidak berwenang yang mencoba mengakses data.

Solusi: Firewall, encryption, intrusion detection

Analisis Kasus: Sistem Pembayaran Online

Situasi

Sebuah perusahaan memiliki sistem pembayaran online yang digunakan untuk menerima pembayaran dari pelanggan.

Masalah: Beberapa transaksi tidak tercatat pada laporan keuangan, menyebabkan ketidaksesuaian antara data transaksi dan laporan.

Pertanyaan Diskusi

- 1 Jenis risiko apa yang terjadi dalam kasus ini?
- 2 Kontrol apa yang seharusnya diterapkan?
- 3 Bagaimana auditor harus mendeteksi masalah ini?

Analisis & Solusi

Identifikasi Risiko

- > Inherent Risk: Kompleksitas sistem pembayaran online
- > Control Risk: Lemahnya pengendalian input/output
- > Information Risk: Ketidakakuratan data transaksi

Kontrol yang Diperlukan

- > Input Control: Validasi setiap transaksi masuk
- > Process Control: Balancing test antar sistem
- > Output Control: Rekonsiliasi harian transaksi
- > Database Control: Audit trail lengkap

Prosedur Auditor

- > Rekonsiliasi data transaksi dengan laporan keuangan
- > Uji sampel transaksi untuk melacak ke sistem
- > Evaluasi efektivitas pengendalian yang ada

Referensi



Jones & Rama (2003)

Accounting Information Systems: A Business Process Approach. Thomson South-Western.



IAI - Ikatan Akuntan Indonesia

Standar Akuntansi Keuangan (SAK) dan Standar Profesional Akuntan Publik (SPAP).



Hunton, Bryan, Barganof (2004)

Core Concepts of Accounting Information Systems. 9th Edition. John Wiley & Sons.



ISACA

COBIT Framework for IT Governance and Control Objectives for Information and Related Technologies.



Chusing (1983)

Internal Control Framework and Accounting Information Systems. McGraw-Hill.



Materi Perkuliahan

Mata Kuliah Audit Sistem Informasi - Program Studi Sistem Informasi, Universitas Jenderal Achmad Yani.

Terima Kasih

Selamat Belajar dan Semoga Sukses!